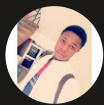




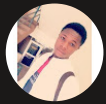
nextwork.org

Secure Packages with CodeArtifact



Ahmed Tetteh

Packages Info					
Filter by package name prefix, format, namespace prefix, and origin controls					
	Package name	Namespace	Format	Latest version	Latest publish date
☐	backport-util-concurrent	backport-util-concurrent	maven	3.1	42 minutes ago
☐	classworlds	classworlds	maven	1.1	43 minutes ago
☐	google	com.google	maven	1	42 minutes ago
☐	jsr305	com.google.code.findbugs	maven	2.0.1	42 minutes ago
☐	google-collections	com.google.collections	maven	1.0	42 minutes ago
☐	commons-cli	commons-cli	maven	1.0	43 minutes ago
☐	commons-logging-api	commons-logging	maven	1.1	42 minutes ago
☐	junit	junit	maven	3.8.2	42 minutes ago
☐	log4j	log4j	maven	1.2.12	42 minutes ago
☐	apache	org.apache	maven	13	43 minutes ago
☐	maven	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-artifact	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-artifact-manager	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-core	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-error-diagnostics	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-model	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-monitor	org.apache.maven	maven	2.2.1	42 minutes ago



Introducing Today's Project!

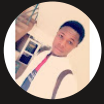
In this project, I will demonstrate how to create a codeArtifact repository to securely store all the web app dependencies. I'm doing this project to learn how CodeArtifact can be used in the CI/CD pipeline or just simply as an Artifact repository for storing packages or dependencies required by an application.

Key tools and concepts

Services I used were AWS CodeArtifact, Amazon EC2, Github, Cloudshell, IAM and VS Code. Key concepts I learnt included: setting up artifact and upstream repositories, connecting Maven with the artifact repository, creating an IAM role for my EC2 instance to access CodeArtifact and creating a security hash for publishing packages.

Project reflection

This project took me approximately 3.5 hours (with research, and troubleshooting time included). The most challenging part was the secret mission where I had to publish a package to my artifact repository using the CLI. I ran into some errors during publishing due to some permission settings and did a bit troubleshooting.. It was most rewarding to all the stored packages within my codeartifact repository, verifying the seamless connection between my Web App on the EC2 instance and CodeArtifact.

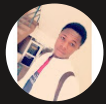


Ahmed Tetteh

NextWork Student

nextwork.org

This project is part three of a series of DevOps projects where I'm building a CI/CD pipeline! I'll be working on the next project with CodeBuild to automatically build my web app on 29th of November.

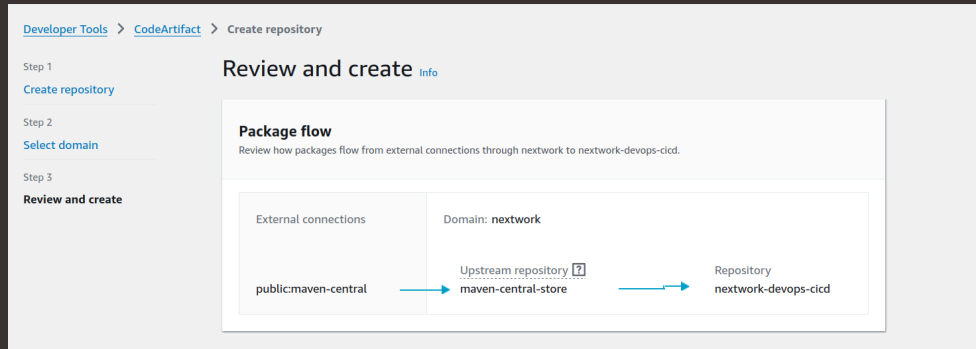
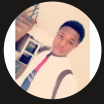


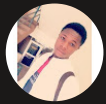
CodeArtifact Repository

CodeArtifact is a artifact repository that secures and stores all your application packages and dependencies in a central location. Engineering teams use artifact repositories because it presents them with a central location to store all the packages they might need for their application to run successfully. It also gives them control over the package versions they all need to work with, instead of them using different versions of the same package.

A domain is like a folder that holds all your repositories belonging to a project or an organization. My domain is "nextwork". They are very helpful to setting up permissions for all the repositories in one go.

A CodeArtifact repository can have an upstream repository, which means that, it can have access to a secondary repository to grab all the necessary packages it does not have locally or privately. My repository's upstream repository is Maven Central Store, a public Java based repository that houses virtually every open-source Java library for multiple applications. Having this setup comes with the benefit of caching, control over package versions and reliability.





CodeArtifact Security

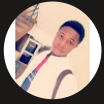
Issue

To access CodeArtifact, we need an authorization token for maven to grab those packages for its build process or package management for about 12 hours. I ran into an error when retrieving a token because my EC2 instance, which has maven installed, does not have the permission to access codeartifact by default, so, it can't present an authorization token for a resource it doesn't know, or hasn't been given permission to access.

Resolution

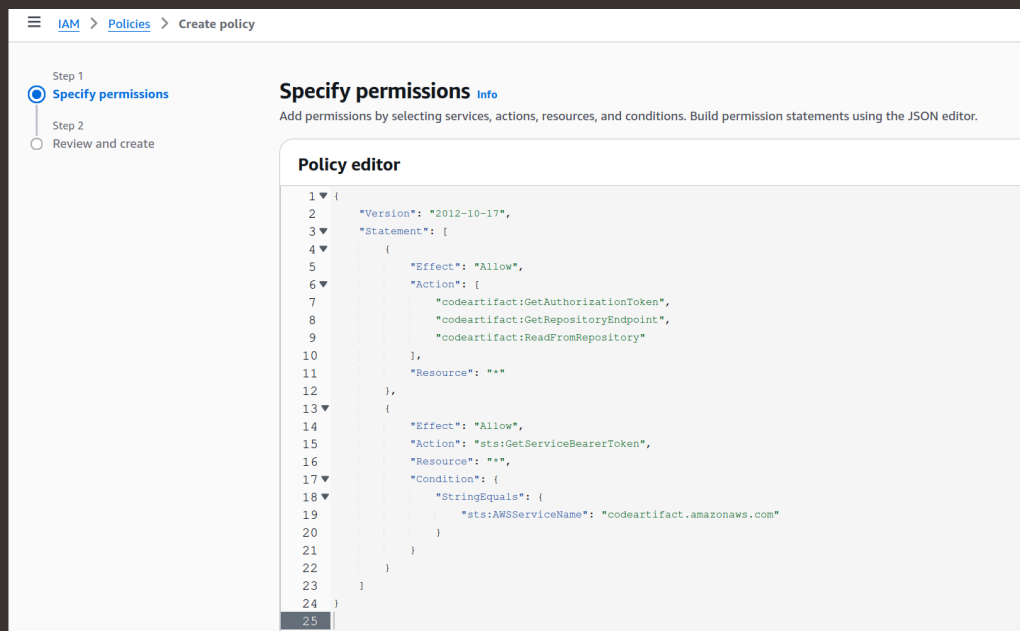
To resolve the error with my security token, I created an IAM role that allows my EC2 instance temporary access to Codeartifact and modified the EC2 instance's security setting to associate itself with that IAM role. This resolved the error because the EC2 instance now has access to request an authorization token from Codeartifact and the Secure Token Service(STS).

It's security best practice to use IAM roles because it grants the an AWS entity(user or service) temporary access to an other AWS resources and perform certain actions. Also, an IAM role comes with temporary rotating security credentials that allows applications(eg: Maven) within services like EC2 instances to make AWS API calls to other services like codeartifact.

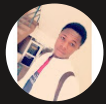


The JSON policy attached to my role

The JSON policy I set up grants permission to access to codeartifact and perform some actions within it. Specifically, to get authorization token for Codeartifact, finding the repository endpoint and viewing the packages in the repository.



```
1 {  
2   "Version": "2012-10-17",  
3   "Statement": [  
4     {  
5       "Effect": "Allow",  
6       "Action": [  
7         "codeartifact:GetAuthorizationToken",  
8         "codeartifact:GetRepositoryEndpoint",  
9         "codeartifact:ReadFromRepository"  
10      ],  
11       "Resource": ""  
12     },  
13     {  
14       "Effect": "Allow",  
15       "Action": "sts:GetServiceBearerToken",  
16       "Resource": "",  
17       "Condition": {  
18         "StringEquals": {  
19           "sts:AWSServiceName": "codeartifact.amazonaws.com"  
20         }  
21       }  
22     }  
23   ]  
24 }  
25
```



Ahmed Tetteh

NextWork Student

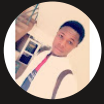
nextwork.org

Maven and CodeArtifact

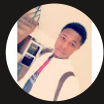
To test the connection between Maven and CodeArtifact, I compiled my web app using settings.xml

The settings.xml file configures Maven to access the artifact repository using an authentication token(i.e. the server section), utilize a specific repository in the profile section for retrieving dependencies, and finally, use the mirror settings to instruct Maven to always refer to the artifact repo first for all dependency requests, even after retrieving from a public repo like Maven Central. So, it's saying, Maven should first check my default repo for dependencies, and if it cannot find them and there are other repos, it can check those ones too. But in this project, we only have one repo, hence, it refers back to itself, then to an upstream repo for the dependencies. To put it simply, the settings.xml file is like an instruction manual for Maven on how to use CodeArtifact. It streamlines the connection between Maven and CodeArtifact.

Compiling means translating code to machine language. It verifies that everything is setup and working as they should.



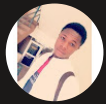
```
1 <settings>
2
3 <servers>
4   <server>
5     <id>nextwork-nextwork-devops-cicd</id>
6     <username>aws</username>
7     <password>${env.CODEARTIFACT_AUTH_TOKEN}</password>
8   </server>
9 </servers>
10
11 <profiles>
12   <profile>
13     <id>nextwork-nextwork-devops-cicd</id>
14     <activation>
15       <activeByDefault>true</activeByDefault>
16     </activation>
17     <repositories>
18       <repository>
19         <id>nextwork-nextwork-devops-cicd</id>
20         <url>https://nextwork-007399901516.d.codeartifact.ap-northeast-1.amazonaws.com/maven/nextwork-devops-cicd</url>
21       </repository>
22     </repositories>
23   </profile>
24 </profiles>
25
26 <mirrors>
27   <mirror>
28     <id>nextwork-nextwork-devops-cicd</id>
29     <name>nextwork-nextwork-devops-cicd</name>
30     <url>https://nextwork-007399901516.d.codeartifact.ap-northeast-1.amazonaws.com/maven/nextwork-devops-cicd</url>
31     <mirrorOf>*</mirrorOf>
32   </mirror>
33 </mirrors>
34
35 </settings>
36
```



Verify Connection

After compiling, I checked my private local artifact repository (nextwork-devops-cicd). I noticed about 4 pages of packages that have now been stored or cached in my artifact repository through the Maven Central Store.

Packages info					
Filter by package name prefix, format, namespace prefix, and origin controls					
	Package name	Namespace	Format	Latest version	Latest publish date
☐	backport-util-concurrent	backport-util-concurrent	maven	3.1	42 minutes ago
☐	classworlds	classworlds	maven	1.1	43 minutes ago
☐	google	com.google	maven	1	42 minutes ago
☐	jsr305	com.google.code.findbugs	maven	2.0.1	42 minutes ago
☐	google-collections	com.google.collections	maven	1.0	42 minutes ago
☐	commons-cli	commons-cli	maven	1.0	43 minutes ago
☐	commons-logging-api	commons-logging	maven	1.1	42 minutes ago
☐	junit	junit	maven	3.8.2	42 minutes ago
☐	log4j	log4j	maven	1.2.12	42 minutes ago
☐	apache	org.apache	maven	13	43 minutes ago
☐	maven	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-artifact	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-artifact-manager	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-core	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-error-diagnostics	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-model	org.apache.maven	maven	2.2.1	42 minutes ago
☐	maven-monitor	org.apache.maven	maven	2.2.1	42 minutes ago



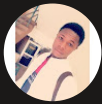
Uploading My Own Packages

In a project extension, I also decided to practice more of package management, by creating my own package and storing it in my artifact repository. This is useful in situations for creating custom packages, as is practiced in companies whereby libraries are made and kept in-house/privately without exposing them to the public.

To create my own package, I compressed a custom text file using the 'tar.gz' command. I also generated a security hash because the integrity of the file needs to be verified by codeartifact before it is stored in the repository. To ensure that the file hasn't been tampered with during upload.

To publish the package, we run the AWS CLI codeArtifact command for publishing packages, along with some few metadata about the package, including the package version, namespace and the repository the package will be published to. When I look at the package details in CodeArtifact, I can see the version number, publish date, the security hash info for the package verification process, and the origin of the package(which, in this case, is the CodeArtifact repository since it wasn't downloaded from a public repository).

To validate my packages, I tried to download the package using cloudshell terminal since my EC2 instance does not have the permission to do so. I saw the package downloaded in the Cloudshell terminal, extracted it and read the contents of the package or file. This validated the very same custom text file we created for publishing.



```
[ec2-user@ip-172-31-32-127 network-web-project]$ aws codeartifact publish-package-version --domain nextwork --repository nextwork-devops-cird --format generic --namespace secret-mission --package agent-package --package-version 1.0.0 --asset-content secret-mission.tar.gz --asset-name secret-mission.tar.gz --asset-sha256 $ASSET_SHA256
{
  "format": "generic",
  "namespace": "secret-mission",
  "package": "agent-package",
  "version": "1.0.0",
  "versionRevision": "32J5YR9HfR09gL68hVAnQ8u0DgI4hukn3Gv+HA50Ive",
  "status": "Published",
  "asset": {
    "name": "secret-mission.tar.gz",
    "size": 157,
    "hashes": {
      "MD5": "381329ff7e368335740a83ed332439d9",
      "SHA-1": "3b3cd948ea0fb14695f8754efb0781c622bda856",
      "SHA-256": "8ea5924e83f6a8a17cc65d7c28cd81d13b2e8a1207d8fc74025b84693283c37",
      "SHA-512": "1cf652e55a3c67dbce9a33483c1307af2a3cb2b6b6a5e80327882ff89b12862fc387d289b996d778ea3df5de809bf03fc736d39159c86b10c4531d82853273"
    }
  }
}
```




nextwork.org

The place to learn & showcase your skills

Check out nextwork.org for more projects

